

Introdução a Auditoria de Sistemas

Sprint - 4

Alunos:

Caio Souza

Julio Cezar

Lucas Miranda

Lucas Papellas

Victor Merlling

Estudo de Caso: Auditoria de Sistemas na Equifax

Introdução

A Equifax é uma empresa norte-americana especializada em serviços de crédito e análise de informações financeiras. Fundada em 1899, a organização armazena dados pessoais e financeiros de milhões de consumidores e empresas em diversos países. Em setembro de 2017, a empresa tornou-se alvo de um dos maiores incidentes de segurança da informação já registrados, quando aproximadamente 147 milhões de pessoas tiveram seus dados pessoais comprometidos.

O caso Equifax tornou-se referência mundial na área de auditoria de sistemas, pois evidenciou como falhas na gestão de vulnerabilidades, nos controles internos e na governança de TI podem causar prejuízos financeiros, danos à reputação da empresa e perda da confiança dos clientes.

1. Contextualização da Empresa

A Equifax atua no setor de serviços financeiros oferecendo análises de crédito, identificação de fraudes, gestão de riscos e informações cadastrais para bancos, seguradoras e empresas de diversos segmentos.

Como sua atividade depende do armazenamento de grandes volumes de informações sensíveis, a segurança da informação representa um dos principais pilares do negócio.

2. Escopo da Auditoria

Após o incidente de segurança, foi realizada uma auditoria abrangendo:

- * Servidores Web;
- * Banco de dados de clientes;
- * Sistema de gerenciamento de vulnerabilidades;
- * Controle de acesso dos administradores;
- * Monitoramento de eventos de segurança;
- * Processo de atualização (patch management);
- * Firewalls;
- * Infraestrutura de rede;
- * Plano de resposta a incidentes.

O objetivo foi identificar as causas do ataque e avaliar a eficiência dos controles existentes.

3. Objetivos da Auditoria

A auditoria teve como objetivos:

- * identificar a origem da invasão;
- * avaliar os controles de segurança;
- * verificar falhas na atualização dos sistemas;
- * analisar a gestão de riscos;
- * avaliar a eficiência do monitoramento de segurança;
- * propor melhorias para evitar novos incidentes.

4. Metodologia Utilizada

A auditoria foi desenvolvida em várias etapas.

Planejamento

Foi definido o escopo da auditoria e formada uma equipe multidisciplinar composta por especialistas em segurança da informação, infraestrutura e governança de TI.

Levantamento de Evidências

Foram analisados:

- * logs dos servidores;

- * registros de acesso;
- * políticas de segurança;
- * inventário de ativos;
- * documentação técnica;
- * histórico de atualizações.

Testes Técnicos

Os auditores realizaram:

- * análise de vulnerabilidades;
- * revisão das configurações dos servidores;
- * testes dos controles de acesso;
- * análise dos processos de atualização;
- * verificação dos mecanismos de monitoramento.

Avaliação dos Riscos

Cada vulnerabilidade encontrada foi classificada conforme sua probabilidade de exploração e seu impacto sobre a organização.

Ao final, foram documentadas todas as evidências encontradas, as falhas identificadas e as recomendações para mitigação dos riscos.

5. Principais Constatações

A auditoria identificou diversos problemas importantes, entre eles:

- * falha na aplicação de uma atualização de segurança crítica do software Apache Struts;
- * processo ineficiente de gerenciamento de vulnerabilidades;
- * monitoramento insuficiente dos sistemas;
- * demora na identificação da invasão;
- * deficiência na gestão de ativos de TI;
- * controles internos que não impediram o acesso não autorizado aos dados.

Essas falhas permitiram que invasores permanecessem **na rede por vários dias antes da detecção do ataque.**

6. Recomendações

O relatório recomendou:

- * implementação de um processo rigoroso de gerenciamento de vulnerabilidades;
- * atualização imediata de softwares críticos;
- * utilização de autenticação multifator para administradores;
- * monitoramento contínuo utilizando ferramentas SIEM;
- * testes periódicos de segurança;
- * auditorias internas frequentes;
- * treinamentos para equipes de TI;
- * fortalecimento da governança de segurança da informação.

7. Resultados Obtidos

Após o incidente, a Equifax realizou investimentos significativos em segurança cibernética, modernizou sua infraestrutura tecnológica, ampliou seus programas de auditoria interna e fortaleceu seus processos de gestão de riscos.

Além disso, a empresa reformulou diversas políticas de segurança e passou a investir continuamente em monitoramento e prevenção de ataques.

Conclusão

O caso Equifax demonstra que a auditoria de sistemas desempenha um papel essencial na prevenção de incidentes de segurança. Caso

processos mais eficientes de auditoria, monitoramento e gerenciamento de vulnerabilidades tivessem sido adotados antes de 2017, o impacto do ataque poderia ter sido significativamente reduzido.

Esse estudo evidencia que a auditoria de sistemas deve ser encarada como uma atividade contínua e estratégica, capaz de identificar riscos antes que eles se transformem em incidentes capazes de comprometer milhões de registros e causar prejuízos financeiros e reputacionais à organização.

Referências (ABNT)

APACHE SOFTWARE FOUNDATION. ****Apache Struts Security Bulletins****. Disponível em: <https://struts.apache.org/security/>. Acesso em: 29 jun. 2026.

EQUIFAX. ****Data Breach Settlement****. Disponível em: <https://www.equifaxbreachsettlement.com/>. Acesso em: 29 jun. 2026.

EQUIFAX. ****Security Updates****. Disponível em: <https://www.equifax.com/>. Acesso em: 29 jun. 2026.

IMONIANA, Joshua Onome. ***Auditoria de Sistemas de Informação***. 3. ed. São Paulo: Atlas, 2016.

ISACA. ***COBIT 2019 Framework: Governance and Management Objectives***. Schaumburg: ISACA, 2019.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27001:2022**. Rio de Janeiro: ABNT, 2022.